Keshav Infotech

Multi-Brand AI Chatbot Platform

Software Requirements Specification — Complete Final Version

Hi,

Thank you for your detailed feedback through the review process. This consolidated SRS reflects the complete agreed scope, including the original specifications (Sections 1–10), the first round of additional specifications added after initial client review (Sections 11–19), and the second round of additions covering production-grade operational, security, and channel features (Sections 20–28).

Kindly review the complete document for final approval, so we can move to Statement of Work and project kickoff.

1. Project Overview

A multi-brand AI chatbot platform that allows the client to manage independent chatbot instances for each brand from a single admin dashboard. Each brand operates in complete isolation with its own tone, knowledge base, compliance rules, and product data.

One platform. Multiple brands. Zero cross-contamination.

2. Core Modules

2.1 Brand Management & Isolation

Every brand is a fully isolated tenant within the system. No data, tone rules, or product information is shared between brands unless explicitly configured.

Feature	Description
Brand Profiles	Each brand has its own name, logo, theme colors, and metadata
Data Isolation	Separate database namespaces, vector DB collections, and storage buckets per brand
Independent Config	Tone rules, compliance rules, product data, FAQs are all brand-specific
Scalable Onboarding	New brand can be added via admin panel without any code changes
Scalable Multi-Brand	The system supports multiple brands with full isolation. Architecture is designed for initial support of 5–10 brands, extensible for higher scale through infrastructure upgrades.
Zero-Code Brand Setup	Adding a new brand requires no developer involvement. Admin configures brand name, tone, products, compliance rules, and channel integrations from the dashboard.

2.2 AI Conversation Engine

The core AI layer uses Claude API with Retrieval-Augmented Generation (RAG) to deliver brand-aware, knowledge-grounded responses.

Component	Details
LLM Provider	Claude API (Sonnet) — primary conversational model
RAG Pipeline	User query → Vector search (brand namespace) → Context injection → LLM response
Brand System Prompt	Each brand has a unique system prompt defining tone, vocabulary, and personality
Conversation Memory	Session-based context window to maintain multi-turn conversations
Hallucination Control	Responses are strictly grounded to the brand's knowledge base; no fabricated claims

2.3 Modular Knowledge Base

Each brand maintains its own knowledge base containing product data, FAQs, routines, and brand rules. Data is embedded and stored in a vector database for semantic search.

Data Type	Storage & Handling
Product Catalog	PostgreSQL (master record: name, description, ingredients, price, image URL) + Vector DB (text embeddings for semantic search)
Product Images	Stored in S3/Cloud Storage; URL referenced in PostgreSQL; served to users via channel-specific media APIs
FAQs	Stored in PostgreSQL, embedded in Vector DB per brand namespace
Routines/Regimens	Multi-step routine builder; stored as structured JSON in PostgreSQL, embedded text in Vector DB
Brand Rules	Allowed/disallowed phrases, compliance rules stored in PostgreSQL and injected into system prompt
Image Style Profile	Each brand defines its own image-style rules (e.g., soft-luxury, clinical-luxury, K-beauty minimal, botanical, modern-clean)
Product Card Styling	Image presentation style for product cards follows brand image rules (rounded vs. sharp edges, background color, overlay style)
Routine Card Styling	Visual style for routine step cards matches brand aesthetic
UI Element Styling	All chatbot UI elements (buttons, cards, backgrounds) follow the brand's defined visual style

Note: Image-style rules are configurable per brand from the Admin Panel. Each brand's chatbot interface and product visuals must reflect its unique aesthetic identity.

2.4 Tone & Personality Engine

Each brand defines its own communication personality. The tone engine shapes every AI response to match the brand's voice.

Parameter	Description
Vocabulary Rules	Preferred and avoided words/phrases per brand
Emotional Style	Warm, clinical, luxurious, friendly — configurable per brand
Communication Style	Formal vs casual, emoji usage, response length preferences
Greeting & Sign-off	Custom opening and closing messages per brand
Response Length	Each brand defines preferred response length: Short / Medium / Long. AI strictly follows the configured length per brand.
Short Mode	Crisp, elegant, 1–2 sentence replies. Ideal for luxury brands
Medium Mode	Balanced replies with necessary detail. 2–4 sentences.
Long Mode	Detailed, informative replies when the brand requires in-depth responses.

Micro-Tone Rules

Parameter	Description
Softness Level	Configurable softness intensity per brand (gentle, neutral, direct)
Sensory Language	Enable or restrict sensory words (e.g., "silky", "velvety", "luminous") per brand
Emotional Cues	Define emotional undertones: calming, uplifting, nurturing, confident
Restricted Adjectives	List of adjectives that must not be used per brand (e.g., "cheap", "basic", "harsh")
Clinical Language Control	Clinical or medical-sounding terms are blocked by default unless explicitly allowed per brand
Harsh Word Blocking	Words that feel aggressive, blunt, or non-premium are automatically filtered

Note: Micro-tone rules allow each brand to fine-tune the emotional feel of every AI response beyond basic tone settings. These are independently configurable per brand from the Admin Panel.

2.5 Product-Safe & Compliance Logic

A guardrails layer sits between the AI engine and the user, ensuring every response passes compliance checks before delivery.

Rule	Implementation
No Medical Claims	System prompt instructs no diagnosis/treatment claims; post-processing filter catches violations
Blocked Phrases	Admin-defined disallowed phrases are checked against every response before sending
Safe Ingredients	No unsafe usage advice; responses only reference brand-approved ingredient information
Fallback Handling	If AI cannot answer safely, it responds with a predefined safe fallback message
Brand-Specific Fallback Tone	Each brand can define its own fallback tone profile inside the admin panel. The fallback tone activates automatically whenever the AI cannot answer safely or a compliance rule is triggered.
No Over-Explaining	AI must keep responses concise and within the brand's defined response length. No unnecessary elaboration.
No Medical Tone	AI must not sound clinical or diagnostic unless the brand explicitly allows clinical language.
No Aggressive Upselling	AI must not push products aggressively. Recommendations must feel natural, not salesy.
No Unnecessary Details	AI must only share information that directly answers the user's question. No filler content.

Note: Conversation boundaries are configurable per brand from the Admin Panel. These rules ensure the chatbot behaves like a premium brand advisor, not a generic bot.

2.6 Routine & Recommendation Logic

The chatbot can guide users through personalized skincare routines based on their skin type, concerns, and preferences.

Feature	How It Works
Skin Profiling	Guided questions to determine skin type (oily, dry, combination, sensitive) and concerns (acne, aging, hydration)
Multi-Step Routines	Admin-defined step sequences (cleanse → tone → serum → moisturize) mapped to brand products
Adaptive Logic	Recommendations change based on user answers; each brand has its own

Feature	How It Works
	recommendation rules
Product Mapping	Each routine step maps to specific products from that brand's catalog with images and descriptions

Note: Detailed recommendation rules engine (priority, exclusion, conflict rules, suitability matrix) is specified in Section 24.

2.7 Multi-Channel Integration

One AI engine serves all channels. The channel layer handles message format conversion and platform-specific API calls.

Channel	Integration Method	Key Notes
Website Chat	Custom React widget + WebSocket	Embeddable via script tag; fully branded per brand
WhatsApp	WhatsApp Business API (Meta Cloud API)	Webhook-based; 24hr reply window; template messages for outbound
Instagram DM	Meta Graph API	Connected via brand's Instagram Business account

2.8 Admin Panel

A web-based dashboard for the client to manage all brands, products, rules, and chatbot configurations without any code.

Screen	Functionality
Dashboard	Overview of all brands, total conversations, active users, channel stats
Brand Manager	Add/edit/delete brands; configure brand name, logo, colors, description
Tone Settings	Define vocabulary, emotional style, communication style, micro-tone rules, response length, greetings per brand
Product Manager	Add/edit products with name, description, ingredients, images, price; auto-embeds to vector DB
FAQ Manager	Add/edit FAQ entries per brand; auto-embeds to vector DB on save
Routine Builder	Create multi-step routines; map products to steps; set skin-type conditions
Compliance Rules	Manage allowed/disallowed phrases, blocked topics, conversation boundaries per brand

Screen	Functionality
Image-Style Rules	Define visual aesthetic per brand for product cards, routine cards, and UI elements
Channel Config	Connect WhatsApp numbers, Instagram pages per brand
Conversation Logs	View chat history per brand/channel; flag and review flagged conversations
Analytics	Message volume, popular questions, response quality metrics, channel breakdown
Tone Override	Admin can override tone and personality settings for any brand at any time
Vocabulary Override	Admin can instantly update preferred/avoided words and phrases per brand
Compliance Override	Admin can modify compliance rules, blocked phrases, and safety settings in real-time
Routine Override	Admin can update, reorder, or replace routine logic and product mappings per brand
Emergency Override	Admin can instantly disable a brand's chatbot or switch it to a safe-mode fallback response

Note: All override controls take effect immediately without requiring any system restart or redeployment. The founder retains full real-time control over every aspect of each brand's chatbot behavior.

3. System Architecture

3.1 Architecture Flow

User Message (any channel) → Webhook/API → Channel Router → Brand Identifier → Load Brand Config → Vector DB Search (brand namespace) → Claude API (brand system prompt + context) → Compliance Filter → Response (via same channel API)

3.2 Data Flow: Product Image Handling

When an admin adds a product: Image uploads to S3 (returns URL), product record saves to PostgreSQL (with image URL), text content chunks and embeds into Vector DB (with product_id reference). When a customer asks about a product: Vector DB returns matching text + product_id, PostgreSQL lookup fetches image URL and full details, AI generates response text, response sent with product image via channel-specific media API.

4. Technology Stack

Layer	Technology
Backend API	Python / FastAPI
AI / LLM	Claude API (Sonnet) via Anthropic SDK
Vector Database	pgvector (PostgreSQL extension) — brand-isolated namespaces
Relational Database	PostgreSQL — brands, products, users, configs, logs
Task Queue	Celery + Redis — async webhook processing, embedding jobs
File Storage	AWS S3 or equivalent — product images, brand assets
Admin Panel	React.js + Tailwind CSS
Chat Widget	React embeddable component + WebSocket
WhatsApp	WhatsApp Business API (Meta Cloud API)
Instagram DM	Meta Graph API
Embeddings	Voyage AI / OpenAI Embeddings API
Hosting	AWS / GCP (Cloud Run / ECS)

5. Admin Panel Scope

Detailed admin panel scope covers Dashboard, Brand Management, Tone & Personality Module, Compliance & Safety Rules, Product & Knowledge Management, Routine & Recommendation Management, and Integration Settings. (Full screen-by-screen functionality is captured in Section 2.8 above and expanded in Sections 21–25.)

6. Chatbot User Side Scope

Chatbot interface elements include: brand-themed chat window, welcome message, user input box, AI-generated message bubbles, and quick reply options. The chatbot handles FAQ responses, product-safe replies, follow-up questions, skincare routine suggestions, and adaptive conversation. (Detailed user-facing screens are listed in Section 7.)

7. Chatbot User-Facing Screens

Screen / Flow	Description
Welcome Screen	Brand-specific greeting with logo and intro message; quick-action buttons (Browse Products, Skin Quiz, FAQ)

Screen / Flow	Description
Chat Interface	Message bubbles, typing indicator, product cards with images, routine step cards
Skin Quiz Flow	Guided questions: skin type, concerns, preferences → personalized routine recommendation
Product Card	Inline card with product image, name, price, short description, and link to purchase
Routine Display	Step-by-step routine (Step 1: Cleanse with X, Step 2: Tone with Y) with product images
Fallback Message	When AI cannot answer safely: brand-specific fallback message in the brand's fallback tone

8. Platforms Covered

Platform	Type	Built By Us	Phase / Notes
Website Chat	Widget	Yes (full UI)	Phase 1 — Embed via script tag
WhatsApp	API Integration	Backend only	Phase 2 — UI is WhatsApp app
Instagram DM	API Integration	Backend only	Phase 2 — UI is Instagram app
Admin Panel	Web App	Yes (full UI)	Phase 1 — React dashboard

9. Client-Side Requirements

The following items are required from the client's side to proceed with development and integration:

Requirement	Details	Phase
Brand Content	Product data (names, descriptions, images, ingredients, prices), FAQs, tone guidelines per brand	Phase 1
Hosting / Domain	Cloud hosting account (AWS/GCP) or we can set up on client's behalf	Phase 1
Anthropic API Key	Required for AI conversation engine. Client must set up Anthropic account with active billing.	Phase 1

Requirement	Details	Phase
	Usage-based paid API.	
Embeddings API Key	Required for vector search (Voyage AI or OpenAI). Usage-based paid API.	Phase 1
Cloud Storage (S3)	Required for storing product images and brand assets. Usage-based paid service.	Phase 1
Meta Business Account	Required for WhatsApp Business API and Instagram DM integration	Phase 2
WhatsApp Business Approval	Phone number per brand; Meta verification; message template approvals	Phase 2
Instagram Business Pages	Admin access to each brand's Instagram Business account	Phase 2

10. Summary

This document outlines the complete technical architecture for a multi-brand AI chatbot platform tailored for the client's skincare brands. The system is designed with brand isolation at its core, ensuring each brand operates independently with its own AI personality, knowledge base, compliance rules, and product catalog.

The platform covers three key layers:

- A founder-level Admin Panel for no-code brand management, including detailed controls for tone, compliance, products, routines, and channel integrations
- A channel-agnostic AI engine powered by Claude API and RAG, delivering brand-accurate, compliant, and personalized responses
- Multi-channel delivery across website, WhatsApp, and Instagram with a consistent user-facing experience

ADDITIONAL SPECIFICATIONS (Sections 11–19)

The following sections were added based on the first round of client review feedback to ensure production-grade reliability, cost control, operational visibility, and clear delivery terms.

11. Performance & Reliability

11.1 Response Time Targets

The AI chatbot targets a response time of 3 to 6 seconds for standard queries. This includes the full pipeline: channel routing, brand config loading, vector search, Claude API call, compliance filtering, and response delivery.

Parameter	Target
Target Response Time	3–6 seconds (90th percentile). Optimization for faster response times will be an ongoing improvement process.
Timeout Threshold	8 seconds — if AI response exceeds this, system delivers the brand's fallback message instead
Retry Logic	1 automatic retry on Claude API failure before triggering fallback
Vector Search Target	< 500ms per query

Response time depends on third-party API performance (Claude API, Embeddings API) which is outside developer control. Targets are best-effort, not guaranteed SLAs.

11.2 Cold Start Optimization

Optimization	Details
Brand Config Preloading	Frequently used brand configurations are preloaded into memory at server startup
Connection Pooling	Database and Redis connections are pooled to avoid cold connection delays
Common Query Caching	Frequently asked questions and their responses are cached to reduce repeated API calls

12. Cost & Usage Control

Control	Implementation
Max Tokens Per Response	Configurable per brand from admin panel (e.g., 500 tokens for short mode, 1000 for detailed)

Control	Implementation
Rate Limiting	Per-user message limit (e.g., 30 messages per minute) to prevent abuse and spam
Per-Brand API Tracking	Track API consumption (Claude API calls, embedding calls) per brand for cost visibility

API billing (Claude, Embeddings) is the client's responsibility. The system provides usage tracking and configurable limits to control costs.

13. Logging & Observability

The system maintains comprehensive logs for debugging, quality improvement, and operational monitoring.

Log Type	What Is Stored
Conversation Logs	Full user query and AI response per message, stored per brand and per channel
RAG Retrieval Logs	Which documents/chunks were retrieved from vector DB for each query, with similarity scores
Error Logs	API failures (Claude, Embeddings, S3), timeout events, webhook delivery failures
Compliance Logs	Responses that were blocked or replaced by compliance filter, with the reason
Admin Activity Logs	What was changed, when, and by whom (brand config updates, product changes, compliance rule changes)

All logs are accessible from the admin panel. Sensitive user data (if any) is masked in logs.

14. Channel-Specific Behavior

Each channel has different formatting and behavior rules to optimize user experience per platform.

Channel	Response Style	Media Support	Formatting
Website Chat	Rich and detailed (within brand's length setting)	Product cards, routine cards, quick-action buttons	Full HTML, styled per brand
WhatsApp	Concise and conversational	Product images as media messages, interactive buttons	Plain text, minimal formatting
Instagram DM	Short and	Product images as	Plain text, emoji-friendly

Channel	Response Style	Media Support	Formatting
	conversational	media messages, quick replies	if brand allows

15. Conversation Intelligence

15.1 Session Personalization

Within a single session, the chatbot remembers user inputs and avoids re-asking questions already answered.

Feature	Behavior
Skin Type Memory	Once user provides skin type during quiz, it is stored in session and used for all subsequent recommendations without re-asking
Concern Memory	User's skin concerns are retained within the session for contextual follow-ups
Preference Memory	Preferences like fragrance-free or vegan are retained within the session

15.2 Conversation Control

Rule	Implementation
No Repeat Recommendations	System tracks products already suggested in the current session and avoids recommending the same product again unless user explicitly asks
No Repeat Questions	If user already answered a question (e.g., skin type), chatbot does not ask again in the same session
Progressive Conversation	Chatbot builds on previous answers rather than starting over on each message

15.3 RAG Governance

Strict controls on how the AI uses retrieved knowledge base content.

Control	Implementation
Minimum Similarity Threshold	Vector search results below a configurable similarity score (e.g., 0.7) are discarded and not sent to the AI
No Speculative Answers	If no relevant data is found above the threshold, AI triggers fallback instead of guessing
Source Grounding	AI can only use information from the retrieved brand knowledge

Control	Implementation
	base. No external knowledge or fabricated content.

16. Data & Security

16.1 Data Retention & Privacy

Policy	Details
Conversation Data Retention	Chat logs are retained for a configurable period (e.g., 90 days). Older data is automatically purged.
User Data Deletion	Ability to delete specific user conversation data upon request
Data Masking	Sensitive user data (if captured) is masked in logs and analytics
Privacy Compliance	System is designed to support basic GDPR/CCPA compliance requirements

16.2 Backup & Recovery

Component	Backup Strategy
PostgreSQL Database	Automated daily backups with configurable retention period
Vector DB Embeddings	Re-generable from source data in PostgreSQL. Backup of source data is sufficient.
Product Images (S3)	S3 provides built-in redundancy. Cross-region replication available if needed.
Brand Configurations	Stored in PostgreSQL, covered by database backup
Recovery Process	Documented recovery procedure to restore full system from backups within defined timeframe

17. Knowledge Base Update Handling

When brand content is updated through the admin panel, the system automatically keeps the AI's knowledge in sync.

Action	System Behavior
Product Added	Product record saved to PostgreSQL. Image uploaded to S3. Text automatically chunked and embedded into brand's vector DB namespace.
Product Updated	PostgreSQL record updated. Old embeddings deleted from vector DB.

Action	System Behavior
	New embeddings generated and stored.
Product Deleted	Record removed from PostgreSQL. Image removed from S3. Embeddings removed from vector DB. Chatbot stops recommending this product immediately.
FAQ Added/Updated	FAQ saved to PostgreSQL. Old embedding replaced with new embedding. Chatbot uses updated answer immediately.
FAQ Deleted	FAQ removed from PostgreSQL and vector DB. Chatbot no longer references this FAQ.
Embedding Status	Admin panel shows embedding sync status (pending, completed, failed) for each update.
Embedding Failure	If embedding API fails, data is saved to PostgreSQL. Embedding job is queued for automatic retry. Admin is notified.

No stale data is ever served to users. The system ensures AI responses always reflect the latest brand content.

18. Project Delivery Terms

18.1 Definition of Completion

The project will be considered complete when:

#	Criteria
1	All core modules (AI engine, admin panel, website chat widget) are functional and testable
2	All features listed in this SRS are implemented as specified
3	QA checklist is passed and approved by the client
4	System is deployed in production environment
5	Documentation, credentials, and source code are handed over
6	Any feature not explicitly listed in this SRS is out of scope unless agreed separately

18.2 QA Acceptance Criteria

Before production launch, the system must pass a documented QA checklist covering:

#	Test Area
1	Brand isolation — no cross-brand data leakage

#	Test Area
2	Tone accuracy per brand — responses match configured tone and response length
3	Compliance-safe responses — no blocked phrases, no medical claims, no hallucination
4	Product recommendation accuracy — correct products for correct skin types
5	Skin quiz logic — correct routine generated based on user answers
6	Website chat widget — functional, branded, responsive
7	WhatsApp integration — webhook receives and responds correctly (Phase 2)
8	Instagram DM integration — webhook receives and responds correctly (Phase 2)
9	Admin panel — all CRUD operations, tone settings, compliance rules, overrides functional
10	Error handling and fallback behavior — graceful degradation on API failures

Client approval is required before production launch.

18.3 Maintenance & Support Scope

Term	Details
Bug-Fix Period	30 days post-launch bug-fix support included at no additional cost
Response Time	Critical bugs: within 24 hours. Non-critical: within 48–72 hours.
Scope	Bug fixes only. New features, enhancements, or scope changes are quoted separately.
API/Hosting Costs	Paid by the client (Claude API, Embeddings API, AWS/GCP hosting, S3 storage)
Monthly Maintenance	Available as an optional paid engagement if client requires ongoing support beyond the bug-fix period

18.4 Third-Party Dependencies

The system depends on external services. Responsibility is clearly defined:

Service	Client Responsibility	Developer Responsibility
Claude API	Account setup, billing, usage costs	Integration, error handling, fallback on failure
Embeddings API	Account setup, billing	Integration, retry logic on failure
Meta APIs	Business account, verification, phone numbers, page admin access	Webhook implementation, channel routing

Service	Client Responsibility	Developer Responsibility
AWS / GCP	Cloud account, billing	Deployment, server configuration
S3 Storage	Storage billing	Upload/retrieval implementation

Any downtime, rate limiting, or breaking changes from third-party services are outside developer control.

18.5 Phase Priority

Phase	Scope	Dependency
Phase 1	AI backend, RAG pipeline, admin panel, compliance engine, website chat widget	None — standalone delivery
Phase 2	WhatsApp Business API integration, Instagram DM integration, channel routing	Requires Phase 1 to be complete

Developer must deliver all Phase 1 features before go-live. Phase 2 is delivered as a subsequent milestone.

19. Source Code Delivery & Ownership

Full source code (backend, frontend, admin panel, database schema, deployment scripts, and configuration files) will be delivered to the client upon completion. The client will have full ownership and unrestricted rights to use, modify, deploy, and extend the system.

Final delivery includes:

#	Deliverable
1	Full backend source code (FastAPI)
2	Full frontend source code (React admin panel + chat widget)
3	Database schema and migration scripts
4	API documentation
5	Deployment scripts and environment variable documentation
6	Setup and installation instructions

ADDITIONAL SPECIFICATIONS — SECOND REVISION (Sections 20–28)

The following sections were added based on the second round of client review feedback. They lock in production-grade specifications for operational, security, moderation, and channel features required for a safe, controlled, and scalable production deployment.

20. Input Moderation & Prompt Injection Protection (Phase 1)

All user inputs pass through a multi-layered moderation pipeline before reaching the Claude API. This protects the platform from spam, abuse, irrelevant queries, and prompt-injection attempts. Token costs are not incurred for blocked input.

20.1 Input Moderation Pipeline

Layer	Function
Pre-Filter	Length validation, empty input rejection, rapid-fire message detection, non-text payload rejection
Pattern Matcher	Regex and signature-based detection of known prompt-injection patterns: "ignore previous instructions", role redefinition attempts, system prompt extraction attempts, jailbreak phrases
Spam Detector	Repeated identical messages, gibberish detection, message frequency anomalies
Abuse Filter	Profanity and harassment language detection, configurable per brand sensitivity
Off-Topic Classifier	Lightweight LLM-based classifier flags inputs unrelated to the brand's domain
Compliance Bridge	Suspicious inputs are forwarded to the existing compliance logging layer for review

20.2 Prompt Injection Defense

Defense	Implementation
Pattern Detection	Pre-defined library of injection signatures, expandable from admin panel
Role Lock	System prompt structured to ignore user-side role redefinition attempts
Instruction Sandboxing	User input wrapped in delimiters; AI instructed to treat user content as data, not instructions

Defense	Implementation
System Prompt Protection	AI is instructed to never reveal, summarize, or modify its system prompt under any user request
Behavioral Monitoring	Conversation patterns indicating injection attempts are logged and flagged for admin review

20.3 Per-Brand Configuration

Setting	Description
Moderation Sensitivity	Configurable per brand: Low / Medium / High
Response on Block	Configurable: silent drop / polite refusal / brand fallback message
Logging	All blocked inputs are logged in compliance logs with the specific reason
Admin Alerts	Repeated abuse from the same user identifier triggers an admin notification
Allow/Block Lists	Admin can maintain per-brand allow lists and block lists for specific phrases or patterns

Note: Input moderation executes before rate limiting and before any AI call. This ensures abusive or malicious inputs do not consume Claude API tokens, protecting cost and reliability.

21. Role-Based Access Control (Phase 1)

The system supports two roles in Phase 1: Super Admin and Admin. Authentication is enforced at both API and UI layers. All privileged actions are audit-logged. Advanced roles, granular permissions, and custom role definitions are deferred to Phase 2.

21.1 Roles Defined

Role	Permissions
Super Admin	Full system access. Can create, edit, and delete brands. Can invite, assign, and revoke admins. Can manage system-wide settings, secrets, and integrations. Can view logs and analytics across all brands.
Admin	Scoped to one or more assigned brands. Can edit assigned brand's products, FAQs, routines, tone settings, image-style rules, and compliance rules. Can view logs and analytics for assigned brands only. Cannot create or delete brands. Cannot manage other users.

21.2 Authentication

Component	Details
Login Method	Email and password; passwords stored as bcrypt hashes (never plaintext)
Session	JWT-based, configurable token expiry, refresh token support
Password Reset	Email-based secure reset flow with time-limited tokens
Brute-Force Protection	Account lockout after configurable failed attempt threshold
First Login	Forced password change on first login after invitation

21.3 Permission Enforcement

Layer	Mechanism
API Layer	Permission middleware enforced on every admin API route; brand-scoped queries are filtered at the database layer to prevent any cross-brand data leakage
UI Layer	Role-based menu rendering and action button hiding
Audit Trail	Every privileged action logged with user ID, timestamp, IP address, action type, and before/after state where applicable

21.4 User Management Actions

Action	Permitted Role
Invite a new admin	Super Admin only
Assign a brand to an admin	Super Admin only
Revoke admin access	Super Admin only
Reset own password	Any authenticated user
View other users' activity logs	Super Admin only

Note: Phase 2 will introduce custom roles, granular per-feature permissions (e.g., viewer, editor, publisher), and per-brand role assignment for the same user across different brands.

22. Lead Capture & Bot Protection (Phase 1)

The chatbot can collect basic lead information (name, email, optional phone) from users at configurable trigger points. All lead capture and chat widget interactions are protected by reCAPTCHA and suspicious activity detection to prevent bot abuse and protect API costs.

22.1 Lead Capture Configuration

Setting	Description
Capture Trigger	Configurable per brand: on welcome, after N messages, on intent detection, or manual prompt
Form Fields	Name (required), Email (required), Phone (optional and brand-configurable)
Consent Checkbox	GDPR-style consent text, fully editable per brand from the admin panel
Skip Option	Users can skip the form; conversation continues without blocking
Duplicate Handling	Re-captured leads are matched by email and updated rather than duplicated

22.2 Storage & Admin View

Component	Details
Storage	PostgreSQL, brand-isolated tables; sensitive fields encrypted at rest
Admin Panel View	Leads list per brand, sortable, searchable, filterable by date and channel
Export	CSV export per brand with filtering options
Channel Tagging	Source channel (Website / WhatsApp / Instagram) is automatically attached to every captured lead
Right to Delete	Specific user lead data can be deleted on request, per GDPR Article 17
Log Masking	Email and phone are masked in conversation logs and analytics dashboards

22.3 Bot Protection

Layer	Mechanism
reCAPTCHA v3	Invisible verification on chat widget initialization and lead form submission
Per-IP Rate Limit	Distinct from per-user limit; blocks IP-level flooding
Suspicious Activity Detection	Bot-like patterns (rapid messages, identical inputs, missing typing cadence) trigger a CAPTCHA challenge or temporary block
Block List	Admin can block specific IPs or user identifiers from the admin panel

Layer	Mechanism
Honey-Pot Fields	Hidden form fields auto-submitted by bots trigger silent rejection

Note: Lead capture data is stored encrypted at rest. Per Section 16.1 (Data Retention & Privacy), users have the right to request deletion of their data.

23. Secure Per-Brand API Key & Secret Management (Phase 1)

All sensitive credentials (API keys, tokens, webhook secrets) are stored encrypted, isolated per brand where applicable, and never exposed in plaintext through the admin panel or logs. This supports per-brand billing visibility and security isolation.

23.1 Secrets Scope

Secret Type	Isolation Strategy
Anthropic API Key	Each brand can have its own dedicated key, or fall back to a system-default key
Embeddings API Key	Per-brand or shared, configurable per brand
Meta WhatsApp Token	Per-brand (relevant to Phase 2)
Meta Instagram Token	Per-brand (relevant to Phase 2)
S3 Credentials	Shared infrastructure credentials, with brand-scoped bucket paths
Webhook Signing Secrets	Per-brand, unique secret for each outbound webhook (Phase 2)

23.2 Storage & Encryption

Component	Details
Encryption at Rest	AES-256 encryption applied to all secret values before persistence
Storage Layer	Dedicated secrets table in PostgreSQL with row-level access restrictions, or cloud-native secret manager (AWS Secrets Manager / GCP Secret Manager) per deployment choice
Access Control	Only Super Admin can view, add, modify, or delete secrets
Plaintext Exposure	Secrets are never displayed in plaintext in the admin panel; the UI shows last-four-characters or set/not-set status only
Logging	Secret values are never written to any log; only secret keys (names) appear in audit trails

23.3 Admin Panel Behavior

Action	Behavior
Add Secret	Super Admin pastes value; system encrypts immediately; the input form does not retain the original value after submit
Update Secret	Replace-only operation; old value is not visible during update
Delete Secret	Brand falls back to the system-default key where applicable, or feature is disabled if no fallback exists
Test Connection	Admin can validate a key with a test API call without revealing the value
Audit Log	Every secret access, update, or deletion is recorded with user, timestamp, and IP

23.4 Key Rotation

Capability	Detail
Manual Rotation	Super Admin can replace any key at any time
Zero-Downtime	New key is validated through a test call before the old key is replaced
Rollback	Previous key version is retained briefly to allow rollback within a short window
Audit Trail	All rotation events appear in admin activity logs

Note: Per-brand API key isolation also enables granular cost tracking and quota control. If one brand exceeds expected usage, only that brand's key is affected; other brands continue to operate normally.

24. Recommendation Rules Engine (Phase 1)

Product recommendations are generated by a deterministic rules engine that selects valid product candidates, followed by an AI layer that presents the recommendation in the brand's tone. Recommendations are never purely AI-generated — every recommended product passes through a rules-based filter first. This ensures safety, brand consistency, and prevents inappropriate or conflicting product suggestions.

24.1 Rule Types

Rule Type	Description
Skin Type Mapping	Each product is tagged with the skin types it is suitable for (oily, dry, combination, sensitive, normal)
Concern Mapping	Each product is tagged with the concerns it addresses (acne, aging, hydration, hyperpigmentation, sensitivity, dullness)

Rule Type	Description
Priority Score	Per-brand priority weighting; higher-score products surface first for matched users
Exclusion Rule	"Do not recommend product X for users with Y skin type or Y concern"
Conflict Rule	"Do not recommend product X and product Y together in the same routine" (for example, retinol and vitamin C)
Suitability Matrix	Multi-axis compatibility scoring across skin type, concern, sensitivity level, and routine step
Stock Status	Out-of-stock products excluded from recommendations (manual flag in Phase 1)

24.2 Execution Flow

User input → Skin profile extracted (from quiz or conversation) → Rules engine filters product catalog → Priority sort → AI generates natural language recommendation grounded in selected products → Compliance filter → Final response delivered.

24.3 Fallback Handling for Recommendations

Scenario	Behavior
No matching product	Brand-specific fallback message; AI does not invent a product recommendation
Conflicting user input	Bot asks a clarifying question rather than guessing
All candidates blocked by exclusion rules	Fallback to safe general advice with no specific product mention
Multiple high-score candidates	Top N (configurable, default 3) presented to user with brief differentiators

24.4 Admin Configuration

Capability	Detail
Rule Editor UI	Per-brand admin can define, edit, and delete rules without developer involvement
Rule Testing	Test mode to simulate user inputs and preview rule output before publishing
Bulk Import	CSV upload supported for large rule sets (skin type mappings, exclusions)
Rule Logs	All rule executions logged with input, matched products, and applied

Capability	Detail
	filters

Note: Phase 2 will add advanced rule types including seasonal recommendations, time-of-day routines, recommendations based on prior user history, and A/B testing of competing rule sets.

25. Per-Brand Prompt Management with Basic Versioning (Phase 1)

Each brand's system prompt is directly editable from the admin panel. A basic version history is maintained, allowing rollback to any prior version. Diff view is available between any two versions. This enables the founder to iterate quickly on tone and behavior without developer involvement and without redeployment.

25.1 Prompt Editor UI

Component	Detail
Direct Editing	The fully assembled system prompt is displayed and editable in the admin panel
Composed View	Visual breakdown of which sections contribute (tone, vocabulary, compliance rules, brand context blocks)
Live Preview	Test the current prompt against sample user inputs before publishing
Syntax Validation	Basic checks to prevent malformed prompts being published

25.2 Basic Versioning

Capability	Detail
Version History	Every publish creates a new version; previous versions are retained
Retention	Last 20 versions retained per brand in Phase 1; older versions are archived but recoverable on request
Restore	Admin can restore any prior version with one click
Diff View	Side-by-side comparison of any two versions, with added/removed text highlighted
Annotations	Optional comment field per version (e.g., "tweaked tone for Diwali campaign")

25.3 Publishing Workflow

Step	Behavior
Draft	Edits are saved as a draft; the live prompt is unaffected
Publish	Draft becomes the live version; the prior live version is archived to history
Rollback	Restoring an archived version makes it live; the current live version is moved to history
Activity Log	Every publish or rollback is recorded with user, timestamp, and optional annotation

Note: Phase 2 will introduce scheduled publishing, A/B testing of prompt variants, branching for experimentation, multi-admin conflict resolution, and unlimited version history retention.

26. Phase 2 Architectural Readiness

The following features are not included in Phase 1 delivery. The Phase 1 architecture is designed to accommodate these without major rework. Pricing and timeline for Phase 2 features will be confirmed in the Phase 2 Statement of Work.

26.1 Live Agent / Human Escalation

Capability	Phase 2 Scope
Escalation Trigger	User-requested (e.g., "talk to a human") or AI-confidence-based
Agent Inbox	Web-based inbox or integration with existing tools (Slack, Intercom, or similar)
Context Handoff	Full AI conversation history and session state transferred to the human agent
Re-Handoff	Conversation can return to AI after human exit
Availability Hours	Per-brand agent availability windows; outside hours, users get a brand-specific holding message

26.2 SEO Integration & FAQ Schema Support

Capability	Phase 2 Scope
Public FAQ Pages	Per-brand crawlable FAQ pages with schema.org/FAQPage markup
Sitemap Generation	Automated sitemap including FAQ entries, refreshed when content changes
Per-Brand Routing	Subdomain or path-based brand isolation, configurable per brand

Capability	Phase 2 Scope
Indexing Control	Per-brand toggle for search engine indexing

26.3 Advanced Analytics & Conversion Tracking

Metric	Phase 2 Coverage
Fallback Rate	Percentage of queries that triggered the fallback message, tracked per brand
Routine Completion Rate	Percentage of users who complete the skin quiz and routine flow
Click-Through Rate	Clicks on product cards and purchase links
Drop-Off Analysis	Funnel analysis identifying where users leave the conversation
Conversion Tracking	Lead-to-purchase tracking when integrated with CRM
Channel Performance	Comparative performance across Website / WhatsApp / Instagram
Brand Performance	Cross-brand comparison dashboard for the founder
Cohort Analysis	User behavior tracked over time across sessions

26.4 CRM Integration & Webhook Export

Capability	Phase 2 Scope
Outbound Webhooks	Configurable webhook URLs triggered on key events (lead captured, conversation ended, escalation requested)
Native Integration	One native CRM integration in Phase 2 (Shopify, HubSpot, Klaviyo, or Mailchimp — to be selected based on the client's stack)
Lead Export	Scheduled or on-demand CSV and JSON export per brand
External API	Read-only API for external systems to pull conversation data per brand

26.5 Full Versioning & Rollback System

Scope	Phase 2 Expansion
Entities Versioned	Brand config, products, FAQs, routines, compliance rules, image-style rules
Restore Granularity	Each entity can be restored to any prior version independently
Retention	Unlimited or configurable retention per entity

Scope	Phase 2 Expansion
Audit Trail	Full change log with user attribution and reason field
Soft Delete	Deleted entities are recoverable for a configurable period before hard-deletion

26.6 Advanced Admin Permissions & Roles

Capability	Phase 2 Scope
Custom Roles	Beyond Super Admin / Admin: e.g., Brand Manager, Content Editor, Viewer
Granular Permissions	Per-feature permissions (read-only on logs, edit-only on products, publish rights, etc.)
Per-Brand Role Assignment	A single user can hold different roles across different brands
Permission Templates	Pre-defined permission bundles for common use cases

26.7 A/B Testing Support

Capability	Phase 2 Scope
Prompt Variants	Multiple prompt versions per brand, served by traffic split
Tone Variants	Test alternative tone configurations against live traffic
Recommendation Variants	Test different rule sets and measure conversion impact
Metrics	Conversion, engagement, fallback rate per variant
Winner Declaration	Statistical significance tracking, manual or automatic promotion

26.8 Brand-Specific Prompt Versioning (Advanced)

Capability	Phase 2 Scope
Long-Term Retention	Unlimited version history per brand
Scheduled Publishing	Queue prompt changes for future activation (e.g., aligned with campaign launches)
Branching	Create prompt branches for experimentation without affecting the live version
Multi-Admin Collaboration	Conflict resolution when multiple admins edit the same prompt concurrently

27. Final Scope Confirmation Matrix

The tables below confirm inclusion status for every item raised during the client's scope review. Phase 1 items are included in the originally proposed Phase 1 budget. Phase 2 items are included in the Phase 2 budget and will be delivered after Phase 1 go-live.

27.1 Phase 1 — Core Production Chatbot Engine

#	Item	Included	SRS Reference
1	Multi-brand AI chatbot platform	Yes	Section 1, 2.1
2	Brand isolation architecture	Yes	Section 2.1
3	Admin panel	Yes	Section 2.8, 5
4	Website chat widget	Yes	Section 2.7, 7
5	RAG knowledge base system	Yes	Section 2.2, 2.3
6	Product management	Yes	Section 2.3, 2.8
7	FAQ management	Yes	Section 2.3, 2.8
8	Routine / skin quiz logic	Yes	Section 2.6, 7
9	Basic product recommendation rules	Yes	Section 24
10	Compliance and safe fallback logic	Yes	Section 2.5
11	Tone and personality engine	Yes	Section 2.4
12	Session memory and personalization	Yes	Section 15.1
13	Conversation logs	Yes	Section 13
14	RAG retrieval logs	Yes	Section 13
15	Error logs and retry logic	Yes	Section 11.1, 13
16	Rate limiting and abuse prevention	Yes	Section 12, 20
17	Input moderation (spam, abuse, prompt injection)	Yes	Section 20
18	Prompt management from admin panel	Yes	Section 25
19	Basic RBAC (Super Admin + Admin)	Yes	Section 21
20	Lead capture for name and email	Yes	Section 22
21	Backup and recovery process	Yes	Section 16.2

#	Item	Included	SRS Reference
22	Data retention and privacy controls	Yes	Section 16.1
23	Knowledge base auto re-embedding	Yes	Section 17
24	Deployment and setup support	Yes	Section 18.1, 19
25	Full source code ownership	Yes	Section 19
26	Admin activity logging	Yes	Section 13
27	Secure per-brand API key & secret management	Yes	Section 23
28	reCAPTCHA / bot protection for lead forms	Yes	Section 22

27.2 Phase 2 — Channel, Growth, and Advanced Features

#	Item	Included	SRS Reference
1	WhatsApp Business integration	Yes	Section 2.7, 8
2	Instagram DM integration	Yes	Section 2.7, 8
3	Live agent / human escalation	Yes	Section 26.1
4	SEO integration and FAQ schema support	Yes	Section 26.2
5	Advanced analytics and conversion tracking	Yes	Section 26.3
6	CRM integration / webhook export	Yes	Section 26.4
7	Full versioning and rollback system	Yes	Section 26.5
8	Advanced admin permissions and roles	Yes	Section 26.6
9	A/B testing support	Yes	Section 26.7
10	Brand-specific prompt versioning (advanced)	Yes	Section 26.8

28. Scope Boundary Notes

28.1 Definition of "Basic" vs "Advanced"

To prevent ambiguity over what is delivered in Phase 1 versus Phase 2, the following clarifications define the production-ready scope of each feature.

Feature	Phase 1 (Basic) Includes	Phase 2 (Advanced) Adds
Recommendation Rules	Skin-type mapping, concern mapping, priority, exclusion,	Seasonal logic, time-of-day variants, A/B tested rule sets, user history-

Feature	Phase 1 (Basic) Includes	Phase 2 (Advanced) Adds
	conflict, basic suitability matrix	based adjustment
Input Moderation	Spam, abuse, prompt injection, irrelevance detection	Sentiment-based moderation, ML-based abuse classifier with continuous learning
RBAC	Super Admin + Admin roles, brand-scoped permissions	Custom roles, granular per-feature permissions, viewer/editor sub-roles
Lead Capture	Name, email, optional phone, CSV export, GDPR consent	Lead scoring, automated CRM sync, multi-step lead nurturing flows
Bot Protection	reCAPTCHA v3, per-IP rate limit, basic suspicious activity detection	Behavioral biometrics, advanced fingerprinting, real-time threat intelligence
Prompt Management	Direct editor, 20-version history, rollback, diff view	Unlimited history, scheduled publishing, branching, A/B testing
Secret Management	Per-brand isolation, encryption at rest, manual rotation	Auto-rotation, HSM integration, fine-grained secret access policies
Analytics	Message volume, popular questions, response quality, channel breakdown	Fallback rate, completion rate, click-through, drop-off, conversion, cohort analysis

28.2 Out of Scope Unless Quoted Separately

The following items are explicitly out of scope under the current Phase 1 and Phase 2 budgets unless quoted as additional engagement:

- Mobile native applications (iOS, Android)
- Voice-based chatbot interfaces
- Multi-language support (chatbot is English-first in Phase 1; additional languages quoted separately)
- E-commerce checkout integration (the bot links out to brand websites only; no in-bot purchase flow)
- Custom domain SSL setup beyond standard configuration
- Marketing campaign management
- Email or SMS marketing automation
- Content writing for FAQs, product descriptions, or tone guidelines (these are provided by client)
- Product photography and brand asset creation
- Brand identity design
- Custom integrations beyond what is listed in Phase 2

28.3 Assumptions for Timeline & Pricing

The proposed Phase 1 and Phase 2 budgets and timelines assume:

- Client provides all brand content (products, FAQs, tone guidelines, image-style references) per the agreed schedule.
- Client sets up Anthropic, embeddings, hosting, and storage accounts when requested.
- A single founder or designated point of contact serves as the primary decision-maker for approvals and feedback.
- Up to 10 brands at Phase 1 launch; beyond 10 brands may require infrastructure scaling discussed separately.
- English-language deployment in Phase 1.
- Client feedback cycles are returned within 48–72 hours during active development sprints.
- Third-party API behavior (Claude, Embeddings, Meta) remains stable; breaking changes from those providers are outside developer control as per Section 18.4.

28.4 Project Delivery Confirmation

Upon written approval of this consolidated SRS, Phase 1 development will commence. The final timeline, milestone breakdown, and payment schedule will be issued as a separate Statement of Work document for client signature prior to development start.

All terms in Sections 18 (Project Delivery Terms) and 19 (Source Code Delivery & Ownership) remain in effect and apply to every feature listed in this SRS.

— End of SRS —

Ready to proceed to final Statement of Work and payment milestones upon client approval.